

Decision Log — Backend xolvon.com

Format entri mengikuti `PRD.md §92` (Open Decision Protocol) dan aturan `RULES.md §84`: setiap keputusan memiliki **Owner**, **Options**, **Decision**, **Date**, **Impact** — tidak ada keputusan yang diselesaikan diam-diam.

- Tanggal dokumen dibuat: 2026-09-12 (plan T4, `.omo/plans/xolvon-backend-build.md`).
- Entri `DL-001` — `DL-010` adalah keputusan owner yang terkunci (draft `.omo/drafts/xolvon-backend-build.md` bagian "Keputusan owner (LOCKED oleh user)").
- Entri `DL-011` — `DL-012` adalah default yang diadopsi backend dan menunggu tanda tangan owner.
- Konflik antar-dokumen dicatat di bagian [Konflik dokumen](#).
- Item yang masih terbuka diindeks di bagian [Keputusan masih terbuka](#) tanpa entri final.

Keputusan terkunci owner (LOCKED)

DL-001 — Lapisan database

Problem:
Repo memakai `D1Service.query()` langsung (`D1 REST`) sehingga pengembangan lokal butuh kredensial Cloudflare; handbook menetapkan `DatabaseService` + `better-sqlite3` untuk lokal dan jalur migrasi ke `D1` untuk production.

Existing Requirement:
`HANDBOOK_BACKEND.md §2:27-63` dan `§8:484-518`; draft keputusan owner #1.

Options:
– Tetap memakai `D1Service` langsung di semua environment.
– `DatabaseService better-sqlite3 (local.db)` untuk lokal + adapter `D1` di balik kontrak yang sama.

Owner:
Founder/BE Lead

Decision:
Ikuti handbook — `DatabaseService` berbasis `better-sqlite3 (local.db)` untuk development lokal; `D1 REST` dipertahankan hanya sebagai adapter di balik token `DatabaseService` saat `DB_DRIVER=d1`. Diimplementasikan di T1/T3.

Date:
2026-09-12

Impact:
Semua modul meng-inject token `DatabaseService` (bukan `D1Service` langsung); bootstrap lokal sukses tanpa kredensial Cloudflare; `src/database/d1.service.ts` tidak diubah sehingga invarian hardening (commit `0c83956`) tetap terjaga.

DL-002 — Status order final

Problem:
Repo memiliki status keempat `awaiting_verification`, sementara handbook `§3.4 FINAL` dan `SCHEMA.md §33` menetapkan hanya tiga status.

Existing Requirement:
`HANDBOOK_BACKEND.md §3.4:112-120`; `SCHEMA.md §33`; draft keputusan owner #2.

Options:
– Pertahankan `awaiting_verification` sebagai status terpisah.
– Collapse ke 3 status handbook (`pending` | `paid` | `cancelled`).

Owner:
Founder/BE Lead

Decision:
Status order `FINAL`: `pending` | `paid` | `cancelled`. `awaiting_verification` dihapus; submit payment proof tetap diizinkan dan mempertahankan status `pending`. Rekonsiliasi service, interface, migrasi, tes, dan tabel admin dikerjakan di T3.

Date:
2026-09-12

Xcivon Backend Documentation · decision-log.md

Impact:
verifyOrder hanya menerima order pending lalu menyetel paid; tes lama yang memakai awaiting_verification diperbarui eksplisit; SCHEMA.md §33 tidak berubah karena sudah final.

DL-003 — Model sesi

Problem:
Handbook §5.1/§5.5 memakai model session-token getSession(); repo memakai JWT access + refresh token berbasis tabel sessions. Perlu satu model yang dikunci.

Existing Requirement:
HANDBOOK_BACKEND.md §5.1:160–233, §5.5; draft keputusan owner #3.

Options:
– Session-token model handbook (getSession()).
– Cookie httpOnly.
– Pertahankan JWT + refresh token milik repo.

Owner:
Founder/BE Lead

Decision:
Pertahankan model JWT + refresh token milik repo. Deviasi dari handbook getSession() didokumentasikan lewat entri ini.

Date:
2026-09-12

Impact:
AuthGuard tetap membaca Authorization: Bearer; kolom sessions.refresh_token dan sessions.expires_at wajib ada di skema (DL-004); hardening expiry/refresh eksplisit dan pesan generik dikerjakan di T17.

DL-004 — Adopsi Schema V2

Problem:
Kode repo meng-query kolom yang tidak ada di SCHEMA.md maupun migrasi repo (users.status/email_verified/phone_verified, sessions.refresh_token/expires_at, courses.price); handbook §3 menambah tabel dan kolom V2 yang belum diadopsi.

Existing Requirement:
HANDBOOK_BACKEND.md §3:67–154; SCHEMA.md §28, §125–128; draft keputusan owner #4.

Options:
– Kembalikan kode ke skema lama.
– Adopsi Schema V2 penuh + sinkronisasi SCHEMA.md.

Owner:
Founder/BE Lead

Decision:
Adopsi Schema V2: tabel course_tags, project_tags, dan FTS5 (course_fts, project_fts, marketplace_fts); kolom sessions.refresh_token/expires_at/ip_address/user_agent, users.status/email_verified/phone_verified, courses.price, collective_members.display_order. Status enrollment FINAL active|revoked – expired dihapus, kolom expires_at dipertahankan dan ditegakkan di query. SCHEMA.md disinkronkan melalui proses perubahan skema eksplisit (T2).

Date:
2026-09-12

Impact:
Migrasi V2 19 tabel + index + FTS5 idempoten; SCHEMA.md menjadi sumber kebenaran tunggal; entity/field/enum baru di luar kontrak wajib memperbarui SCHEMA.md + entri decision log sebelum implementasi.

DL-005 — Admin bootstrap

Problem:

PRD \$91.8 mekanisme membuat admin pertama belum final; route registrasi admin publik dilarang.

Existing Requirement:

PRD \$91.8, \$44; HANDBOOK_BACKEND.md \$7; ARCHITECTURE.md \$165; draft keputusan owner #5.

Options:

- Route registrasi admin publik.
- Seed script server-side terkontrol.

Owner:

Founder/BE Lead

Decision:

Bootstrap admin via seed script server-side (dijalankan terkontrol di T19).
Tidak ada route publik yang membuat admin; role tidak pernah diterima dari input user.

Date:

2026-09-12

Impact:

Delete dan role-change tidak memiliki endpoint di V1 (PRD \$44 view-only); keadaan ini dicatat resmi di sini, bukan diselesaikan diam-diam. Endpoint admin (T12) murni read + aksi transisi status.

DL-006 — Ratifikasi payment_proofs

Problem:

PRD \$91.6 menyatakan penyimpanan payment proof belum diputuskan, tetapi repo sudah mengimplementasikan tabel payment_proofs + alur submit proof. Konflik implementasi vs dokumen.

Existing Requirement:

PRD \$91.6; SCHEMA.md \$1023-1033 (open decision); draft keputusan owner #6.

Options:

- Hapus tabel dan alur proof.
- Ratifikasi implementasi sebagai keputusan resmi.

Owner:

Founder/BE Lead

Decision:

Tabel payment_proofs dan alur POST /orders/:id/payment-proof diratifikasi sebagai bagian kontrak V1.

Date:

2026-09-12

Impact:

PRD \$91.6 terjawab; yang disimpan adalah object key (bukan berkas); antrean verifikasi admin memakai status order pending (DL-002).

DL-007 — R2 StorageService interface-first

Problem:

Modul media/R2 belum ada dan kredensial R2 production belum tentu tersedia saat pembangunan; implementasi tidak boleh menunggu atau menebak.

Existing Requirement:

HANDBOOK_BACKEND.md \$6:393-414, \$8:521-559; ARCHITECTURE.md \$45-48; draft keputusan owner #7.

Options:

- Tunggu kredensial sebelum menulis kode media.
- Bangun StorageService ke interface, verifikasi menyusul.

Owner:

Founder/BE Lead

Perbedaan PUT 3600, object key digenerate server, prefix sesuai ARCHITECTURE.md \$48. Verifikasi terhadap R2 nyata menyusul saat kredensial tersedia (T13/T19).

2026-09-12

Konsumen (media, lesson video, proof) tidak berubah saat provider ditukar; kredensial tidak pernah masuk kode, tes, atau respons client.

2026-09-12

Keputusan teknis tersebar di plan/chat; RULES.md §84 mewajibkan decision log; SCHEMA.md §95 mewajibkan kontrak pagination dikunci sebelum implementasi.

Existing Requirement:

SCHEMA.md §95:2340–2366; SCHEMA.md §95; draft keputusan owner #10.

Options:

- Catat keputusan hanya di plan/chat.
- Deliverable docs resmi di dalam repo.

Owner:

Founder/BE Lead

Decision:

Wajib ada docs/decision-log.md (berkas ini) dan docs/api-contract.md; api-contract.md diperbarui setiap modul baru dan disempurnakan penuh di T16.

Date:

2026-09-12

Impact:

Tidak ada keputusan yang diselesaikan diam-diam; setiap [OPEN DECISION] memiliki entri Owner/Options/Decision/Date/Impact di berkas ini.

Default yang diadopsi backend

Entri berikut adalah default teknis yang diadopsi backend agar implementasi

tidak terblokir. Keduanya menunggu tanda tangan owner; perubahan nilai setelah

implementasi wajib lewat entri decision log baru dengan owner manusia.

DL-011 — Kontrak pagination

Problem:

SCHEMA.md §95 – pagination behavior belum ditentukan sumber dokumen dan DO NOT ASSUME berlaku; volume data mengharuskan pagination sehingga contract wajib dikunci sebelum implementasi.

Existing Requirement:

SCHEMA.md §95:2287–2298; plan T4 (memblokir T5/T7/T9/T16).

Options:

- Offset-based: ?offset= & ?count=.
- Page-based: ?page= & ?limit=.

Owner:

Backend (default adopted, track owner sign-off)

Decision:

Kontrak pagination: ?page= 1-based, ?limit= default 20 maksimum 100; respons list berbentuk {items, page, limit, total}. Berlaku untuk semua endpoint list (courses, projects, marketplace, search, admin).

Date:

2026-09-12

Impact:

T5/T7/T9/T16 mengikuti kontrak ini; owner dapat mengganti kontrak hanya dengan entri decision log baru sebelum T5 mulai.

DL-012 — Ambang rate limit auth

Problem:

PRD §104 mewajibkan pembatasan percobaan login; auth.controller.ts masih TODO; nilai ambang belum dikunci siapa pun.

Existing Requirement:

PRD §104:2718–2753; HANDBOOK_BACKEND.md §5.1; plan T17.

Options:

- 3 percobaan per menit per IP.

- 5 percobaan per menit per IP.
- 10 percobaan per menit per IP.

Xcivon Backend Documentation · decision-log.md

Owner:

Backend (default adopted, track owner sign-off)

Decision:

Rate limit /auth/login dan /auth/register: 5 percobaan per menit per IP via @nestjs/throttler (T17). Melebihi ambang mengembalikan HTTP 429.

Date:

2026-09-12

Impact:

Implementasi T17 memakai nilai ini; owner dapat mengganti ambang dengan entri decision log baru sebelum T17.

DL-013 — Validasi minimal `external_url` marketplace (governance tetap OPEN)

Problem:

Marketplace item menampilkan CTA ke website SaaS eksternal (PRD §55), tetapi governance `external_url` belum final – PRD §91.11 dan SCHEMA.md §61 menegaskan aturan validasi/pengelolaan URL (valid + approved + managed) masih open decision dan melarang membangun business logic tambahan berdasarkan asumsi. Implementasi T9 tetap butuh aturan minimal agar endpoint tidak menerima nilai berbahaya.

Existing Requirement:

PRD §91.11 (External SaaS URL Governance); SCHEMA.md §61; plan T9.

Options:

- Tanpa validasi (menunggu governance final).
- Validasi minimal: URL absolut valid (URL parse) + https-only; http ditolak.
- Governance penuh: allowlist domain / approval workflow admin.

Owner:

Backend (default adopted, track owner sign-off)

Decision:

Validasi minimal diadopsi untuk V1 di MarketplaceService (create + update): `external_url` harus parse sebagai URL absolut valid DAN berprotokol https; http ditolak dengan 400 (CTA me-redirect visitor keluar situs, target insecure adalah celah redirection security), string non-URL ditolak dengan 400. Governance final (approval/allowlist/management workflow) TETAP OPEN – tidak diimplementasikan dan tidak digantikan asumsi.

Date:

2026-09-12

Impact:

Endpoint marketplace menerima hanya https URL valid sejak T9; owner dapat mengganti/memperketat aturan dengan entri decision log baru tanpa mengubah kontrak respons. Kepatuhan MarketplaceModule sebagai showcase murni (tanpa pembayaran/transaksi, SCHEMA.md §60) tetap berlaku.

DL-014 — `type / mediaType / role` portfolio sebagai string terkontrol (enum final tetap OPEN)

Problem:

Plan T7 membangun modul Portfolio, tetapi SCHEMA.md §45 (project.type), §50 (project_media.media_type), dan §52 (project_members.role) menegaskan enumerasi final belum diputuskan dan melarang mengarang enum sendiri (RULES.md §84:2340–2366). Implementasi tetap butuh aturan validasi minimal.

Existing Requirement:

SCHEMA.md §45/§50/§52; RULES.md §84; plan T7; PRD §26–30.

Options:

- Mengarang enum final (dilarang SCHEMA.md – DO NOT INVENT).
- Menunda modul sampai enum final (memblokir T7 tanpa dasar owner).
- String terkontrol: wajib string non-kosong dengan batas panjang; nilai bebas sampai enum final dikunci owner.

Owner:

Backend (default adopted, track owner sign-off)

Xcvo/decision-Documentation · decision-log.md

Decision:
`type`, `mediaType`, dan `role` divalidasi sebagai string terkontrol (@IsString + @NotEmpty + @MaxLength: type 100, mediaType 50, role 100) di CreateProjectDto/AttachProjectMediaDto/AssignProjectMemberDto – TIDAK ada @IsEnum. Enumerasi final TETAP OPEN (indeks "Keputusan masih terbuka"); menguncinya nanti hanya menambah validator di DTO tanpa mengubah kontrak respons maupun query.

Date:
2026-09-12

Impact:
T7 selesai tanpa asumsi enum; media publik tetap dieksklusi video/object key; perubahan nilai setelah enum final dikunci owner wajib lewat entri decision log baru.

DL-015 — Kolom "WhatsApp / Proof Reference" tabel admin orders

Problem:
PRD §45 mendaftarkan kolom "WhatsApp / Proof Reference if applicable" untuk tabel admin orders/activation, tetapi menandainya belum final. Tabel skema tidak memiliki kolom whatsapp/proof terdedikasi, dan menambahkan field baru di luar kontrak tanpa keputusan owner dilarang (SCHEMA.md §127-128). Implementasi T12 butuh keputusan eksplisit untuk kolom ini.

Existing Requirement:
PRD §45:1266 (kolom belum final); SCHEMA.md §127-128; DL-006 (ratifikasi payment_proofs); plan T12.

Options:
– Menyimpan referensi WhatsApp/proof sebagai kolom dedikasi baru (pada orders atau tabel terpisah) dan mengeksposnya di respons admin.
– Tidak menyimpan kolom dedikasi; baris payment_proofs adalah referensi proof yang sah, dan kontak WhatsApp admin tercantum terpisah di halaman publik.

Owner:
Founder/Product

Decision:
TIDAK ada kolom dedikasi untuk WhatsApp/proof reference di database maupun di respons endpoint admin. Referensi proof of payment tetap merujuk pada baris payment_proofs (object key per order) yang telah diratifikasi di DL-006; kebutuhan tampilan "Proof" di FE membaca dari sana. Kontak WhatsApp admin untuk recovery/reset sudah tersedia sebagai teks statis di halaman publik (PRD §42) dan bukan data transaksi.

Date:
2026-09-12

Impact:
GET /admin/orders (T12) tidak mengembalikan field whatsapp/proof; tidak ada perubahan skema untuk kolom ini. Bila owner kelak menghendaki kolom dedikasi, wajib lewat entri decision log baru + perubahan skema eksplisit (SCHEMA.md §127-128).

DL-015 implementation note — T12 admin proof surface

T12 implements the locked DL-015 decision without adding a WhatsApp/proof field to the admin response. `GET /api/admin/orders` exposes derived activation state and safe order/user fields only; payment proof references remain owned by the existing `payment_proofs` flow, while WhatsApp remains static public contact copy. Any dedicated transaction reference requires a new owner decision and schema change.

DL-016 — Implementasi rate limit auth dengan @nestjs/throttler

Problem:	DL-012 mengunci ambang 5 per cobaan/menit/IP untuk /auth/login dan /auth/register) tetapi belum menetapkan mekanisme implementasinya; auth.controller.ts:37 masih TODO saat T17 dimulai.
Existing Requirement:	DL-012; PRD §104:2718-2753; HANDBOOK_BACKEND.md §5.1:160-233; plan T17.
Options:	- Implementasi manual (counter in-memory + middleware custom). - @nestjs/throttler (ThrottlerModule.forRoot + APP_GUARD + @Throttle per-route).
Owner:	Backend (default adopted per DL-012, track owner sign-off)
Decision:	Mekanisme = @nestjs/throttler ^6.5.0 (versi tercatat di package.json; peer range paket masih sampai ^11 sehingga .npmrc legacy-peer-deps=true ditambahkan). Konfigurasi produksi: global default 100 req/menit/IP per route (ThrottlerModule.forRoot, name 'default', ttl 60000), login DAN register diperketat ke 5 req/menit/IP via decorator @Throttle di AuthController (route metadata meng-override module default di @nestjs/throttler). Semua route lain memakai default 100/menit - /api/health dan konten publik GET tidak dibatasi agresif. Melebihi ambang → HTTP 429 dengan pesan standar throttler ("ThrottlerException: Too Many Requests") tanpa detail internal. Pesan kegagalan login tetap generik "Invalid email or password." untuk unknown-email maupun wrong-password (anti-enumerasi, dipertahankan + diuji). Expiry/refresh eksplisit: sesi kedaluwarsa dihapus (DELETE by id) saat refresh() dan dikembalikan 401 generik - diuji unit.
Date:	2026-09-12
Impact:	Ambang DL-012 kini aktif secara produksi via APP_GUARD ThrottlerGuard. Owner dapat mengganti ambang dengan entri decision log baru; e2e memakai override module-options ketat (3/menit) untuk membuktikan pipeline guard nyata, dan menguji limit login 5/menit sesuai angka produksi.

Konflik dokumen (tercatat + resolusinya)

ID	Konflik	Resolusi		
K-01	Order status: repo memakai <code>awaiting_verification</code> (<code>0001_orders_enrollments.sql:16</code> , <code>orders.service.ts</code>) vs HANDBOOK_BACKEND.md §3.4 FINAL dan SCHEMA.md §33 <code>`pending`</code>	<code>paid`</code>	<code>cancelled`</code>	DL-002 — repo direkonsiliasi ke 3 status (T3)
K-02	Enrollment status: migrasi repo mengizinkan <code>expired</code> vs SCHEMA.md §28 hanya <code>`active`</code>	<code>revoked`</code>	DL-004 — <code>expired</code> dihapus; <code>expires_at</code> dipertahankan dan ditegakkan di query	
K-03	Kolom ekstra: kode meng-query <code>users.status/email_verified/phone_verified</code> (<code>auth.service.ts:58-61</code>) dan <code>sessions.refresh_token/expires_at/ip_address/user_agent</code> (<code>auth.service.ts:150-152</code>) tanpa migrasi maupun entri SCHEMA.md	DL-004 — diadopsi ke Schema V2, SCHEMA.md disinkronkan (T2)		
K-04	Model sesi: handbook <code>getSession()</code> (session-token) vs repo JWT + refresh bearer	DL-003 — repo dipertahankan; deviasi didokumentasikan		
K-05	<code>payment_proofs</code> sudah terimplementasi di repo padahal PRD §91.6 dan SCHEMA.md menandainya open decision	DL-006 — diratifikasi		
K-06	Deployment: handbook §8 Langkah 6/8 memakai jalur <code>vinext /Workers</code> binding; repo BE memakai Node/Express (<code>@nestjs/platform-express</code>) + adapter D1 REST	Akan dicatat resmi sebagai deviasi terdokumentasi saat production (T20); BE tetap Node/Express		

Keputusan masih terbuka

Indeks item PRD §91 dan plan yang **belum** diputuskan — entri final dengan

Owner/Options/Decision/Date/Impact akan ditambahkan saat masing-masing

diputuskan (tidak ada entri placeholder di log ini):

- PRD §91.1 — penempatan Solve On (/solve-on vs Home Section/Anchor).
- PRD §91.2 — auth library final (model sesi sudah dikunci di DL-003).
- PRD §91.3 — password hashing final disesuaikan runtime (repo saat ini: argon2).
- PRD §91.4 — runtime/adaptor deployment final (dikunci di T20, lihat K-06).
- PRD §91.5 — mekanisme/provider QR atau payment.
- PRD §91.7 — assignment: resource saja vs submission workflow.
- PRD §91.9 — legal copy (Terms/Privacy/Disclaimer).
- PRD §91.10 — jumlah konten awal.
- PRD §91.12 — analytics provider pihak ketiga.
- Plan T7 — enum `type` media project (string terkontrol diadopsi di DL-014; enumerasi final masih terbuka).
- Plan T9 — governance `external_url` marketplace (validasi minimal https diadopsi di DL-013; approval/allowlist/management masih terbuka).
- Plan T12 — kolom WhatsApp/proof pada tabel admin (diputuskan di DL-015: tidak ada kolom dedikasi; payment_proofs adalah referensinya).
- T19 — analytics/monitoring provider pihak ketiga (interface `MonitoringPort` tersedia; provider dan credential tetap OPEN sampai keputusan owner).

DL-017 — Environment, admin bootstrap, and monitoring boundary

Problem:

T19 membutuhkan pemisahan local/staging/production, bootstrap admin pertama, dan structured logging/error monitoring tanpa memasukkan credential provider yang belum dipilih.

Existing Requirement:

ARCHITECTURE.md §§79–90/165, RULES.md §52, PRD.md §105, T19 plan.

Options:

- Public admin registration or ad-hoc production seed data.
- Controlled server-side command using `ADMIN_BOOTSTRAP_EMAIL/PASSWORD`.

Owner:

Founder/BE Lead

Decision:

Use `APP_ENV` values local/staging/production with separate secret stores. The server-side ``npm run seed:admin`` command hashes through `PasswordService`, inserts `role=admin`, and is idempotent without a public route or committed credentials. Structured monitoring is represented by `MonitoringPort` only; provider selection and credentials remain OPEN DECISION. Rollback is deployment revert plus backup restore or a reviewed compensating migration; applied migrations are never edited.

Date:

2026-09-12

Impact:

Local dry-run is supported without Cloudflare credentials. Staging/production live deployment and provider selection remain T20 work and are not claimed by T19.

Addendum hardening decisions (T1)

DL-018 — Bearer-only request integrity

Owner:

Founder/BE Lead

Options:

- Add a cookie-backed CSRF token flow.
- Keep the API Bearer-only and enforce browser request-integrity checks using allowed Origin/Referer and Fetch-Metadata policy for mutation requests.

Decision:

Use Bearer-only request integrity. Do not add a CSRF cookie token because the current API authentication contract uses Authorization Bearer tokens rather than cookie authentication. Browser mutation requests will be checked against the explicit request-integrity policy in T3.

Date:

2026-09-12

Impact:

No CSRF cookie or token secret is added. No-cookie Bearer API clients remain supported; GET requests are unaffected. Non-browser service-to-service access requires the explicit policy defined during implementation.

DL-019 — Playwright PDF artifacts

Owner:

Founder/BE Lead

Options:

- Keep documentation as Markdown only or generate PDFs outside the repository.
- Generate Markdown-to-PDF artifacts with Playwright/Chromium and commit them.

Decision:

Use Playwright/Chromium for the approved Markdown-to-PDF workflow. Generated documentation PDFs are committed, including the combined document in the order README, Architecture, Security, and Deployment Runbook.

Date:

2026-09-12

Impact:

PDF output becomes a reviewed repository artifact and must be regenerated and secret-scanned when its source documentation changes. No credentials or private environment values may appear in the source or generated PDFs.

DL-020 — Environment CORS whitelist and origin placeholders

Owner:

Founder/BE Lead

Options:

- Continue using one FRONTEND_URL origin.
- Parse CORS_ALLOWED_ORIGINS as an environment-specific explicit whitelist.

Decision:

Use CORS_ALLOWED_ORIGINS as the explicit whitelist, with a localhost fallback for local development. Staging and production origins remain OPEN placeholders until the owner supplies final domains; wildcard origins are not approved when credentials are enabled.

Date:

2026-09-12

Impact:

T5 must preserve local startup without a final deployment domain and must reject unknown credentialed origins. Staging and production deployment evidence remains blocked until real target origins are provided; no domain is fabricated here.

DL-021 — CSP connect and media origins

Owner:

Founder/BE Lead

Options:

- Allow broad CSP connect-src and media-src values.

- Use explicit environment origin lists and leave unavailable deployment origins open until owner confirmation.

Xcivon Backend Documentation · decision-log.md

Decision:

Use explicit CSP connect-src and media-src origin lists. Final frontend, storage, and other deployment-specific origins remain OPEN placeholders until the owner confirms them. Do not enable unsafe-inline or unsafe-eval as a default.

Date:

2026-09-12

Impact:

T4 must document the approved local baseline and make staging/production CSP origins configurable without embedding unverified domains or secrets.

DL-022 — Monitoring provider and recipients

Owner:

Founder/BE Lead

Options:

- Select a monitoring vendor and alert recipients now.
- Keep MonitoringPort as the boundary until provider and recipient decisions are approved.

Decision:

Monitoring provider and alert recipients remain OPEN. The existing MonitoringPort interface is the only approved integration boundary for this stage; no vendor SDK, endpoint, recipient address, or credential is selected.

Date:

2026-09-12

Impact:

Later monitoring work must record the provider, recipients, data boundary, and secret-store location in a new decision entry before production wiring.

DL-023 — Security scanner choice

Owner:

Founder/BE Lead

Options:

- Adopt a named third-party or paid security scanner.
- Use repository-native scans and npm audit while scanner selection is open.

Decision:

Security scanner choice remains OPEN. T1 records no vendor commitment; current verification uses the repository-native secret-pattern review and the existing quality commands. A future scanner requires explicit owner approval and a new decision entry.

Date:

2026-09-12

Impact:

No scanner credentials, paid service, or CI integration is added. Residual scan coverage and any selected tool must be documented before the final security gate.

DL-024 — Postman production placeholders

Owner:

Founder/BE Lead

Options:

- Commit populated production credentials or target-specific values.
- Commit production environment structure with blank placeholders only.

Decision:

Postman production environments may contain names, URLs marked as placeholders, and blank secret variables only. No access token, password, API key, cookie, or

other production credential may be committed.

Xolvon Addendum Documentation · decision-log.md

Date:
2026-09-12

Impact:
T11 can provide importable production structure without claiming production readiness. Operators must supply values through an external secret-safe workflow.

DL-025 — Conservative cleanup policy

Owner:
Founder/BE Lead

Options:
– Remove ambiguous files and generated artifacts during hardening.
– Preserve source, migrations, evidence, and user changes; remove only proven temporary artifacts with a deletion ledger entry.

Decision:
Use conservative, reversible cleanup. Preserve source, migrations, evidence, approved PDFs, and unrelated user changes. Delete only an artifact proven to be temporary, and record its path and rationale in the cleanup ledger. Do not edit or delete secrets as a substitute for rotation or incident handling.

Date:
2026-09-12

Impact:
T12 must produce an explainable file-by-file cleanup diff and must leave required files intact. Any tracked environment secret requires separate incident handling, not silent cleanup.

DL-026 — DL-019 disposition: official PDF pipeline vs stray Python artifact

Problem:
DL-019 locked the official PDF workflow as Playwright/Chromium Markdown-PDF (`npm run docs:pdf` → `scripts/docs-pdf.mjs`, output `docs/pdf/\*.pdf`, committed). Commit `9a6d1d7` ("feat: add throttle and trust proxy configurations with API documentation and Postman collection") arrived out-of-band and introduced two non-conforming artifacts: `scripts/generate-api-pdf.py` (Python/reportlab generator reading the root Postman collection) and `docs/Xolvon-API-Documentation.pdf` (its output, sitting loose in `docs/`).

Existing Requirement:
DL-019; plan T8/T9/T12 (`omo/plans/xolvon-addendum-hardening-docs.md`); conservative cleanup policy DL-025 (nothing deleted without a ledger entry).

Options:
– Accept the Python-generated PDF as an additional official artifact.
– Delete the stray files immediately during T8.
– Record them as non-conforming and schedule removal/replacement at T9, where the committed Playwright PDFs (individual + combined, order README → Architecture → Security → Deployment Runbook) supersede them and the T12 deletion ledger documents the removal.

Owner:
Founder/BE Lead

Decision:
The only approved PDF generation path is Playwright: official handover docs are Markdown under `docs/` and PDFs are generated exclusively via `npm run docs:pdf` (`scripts/docs-pdf.mjs`). `scripts/generate-api-pdf.py` and `docs/Xolvon-API-Documentation.pdf` are formally declared NON-CONFORMING to DL-019 and scheduled for removal/replacement at T9 (Playwright committed PDFs; combined output covers the Postman-derived API content once T10/T11 reconcile the contract). This entry records the disposition only – per DL-025 the files are NOT deleted at T8; deletion happens in the T9/T12 pass with a deletion ledger line.

Date:
2026-09-12

Impact:

Xolvon API documentation is https://api.xolvon.com/docs/ + the sanctioned Playwright pipeline only; no second PDF generator becomes canonical. Reviewers must not treat the stray Python/PDF pair as authoritative. T9 regenerates all committed PDFs; T12's cleanup ledger carries the eventual deletion of both stray paths.

Disposition (executed at T9, 2026-09-12 — append-only ledger line):

Deleted as scheduled. Files removed: `scripts/generate-api-pdf.py` and `docs/Xolvon-API-Documentation.pdf`. Reason: non-conforming to the locked

Playwright-only PDF pipeline (DL-019/DL-026); superseded by the committed

Playwright outputs `docs/pdf/README.pdf`, `docs/pdf/architecture.pdf`,

`docs/pdf/security.pdf`, `docs/pdf/deployment-runbook.pdf` and

`docs/pdf/xolvon-backend-full-documentation.pdf` (combined order README →

Architecture → Security → Deployment Runbook), all generated by

`npm run docs:pdf (scripts/docs-pdf.mjs)`. No source, test, or script

referenced the deleted paths (workspace grep: zero hits); `docs/README.md`

§6 mentions them only as scheduled-for-removal notes, which this entry

closes. The

commit `9a6d1d7` strays `Xolvon-API.postman_collection.json` and root

`README.md` remain untouched pending T11/T12 disposition.

DL-027 — Final staging/production origins and CSP origins remain OPEN

Problem:

T8 documentation must describe staging/production deployment without inventing domains. DL-020 locked the CORS whitelist mechanism and DL-021 locked the explicit CSP origin-list mechanism, but the concrete values — final staging and production frontend origins and the CSP ``connect-src``/media origins that depend on them — have never been supplied by the owner, and ``docs/qa-results.md`` confirms no real domains exist in this workspace.

Existing Requirement:

DL-020, DL-021; plan T8 acceptance ("all current route/auth decisions are consistent"); addendum open-decision list ("Final staging and production frontend origins", "Final CSP `connect-src``/media origins").

Options:

- Populate example values in the `docs/templates` and treat them as final.
- Leave the decision open with a named owner, documenting the placeholder fallback behavior until final domains exist.

Owner:

Founder/Backend

Decision:

FINAL staging and production frontend origins, and the CSP ``CSP_CONNECT_SRC`` connect/media origin lists derived from them, REMAIN OPEN DECISIONS with owner = Founder/Backend. Until they are supplied: ``CORS_ALLOWED_ORIGINS`` and ``CSP_CONNECT_SRC`` stay unset (CORS falls back to ``FRONTEND_URL``, CSP defaults to ``self`` + ``R2_ENDPOINT`` origin), no domain values are fabricated in docs, templates, Postman, or PDFs, and deployment evidence for those environments remains blocked. Closing this decision requires a new entry here with the exact approved origins per environment.

Date:

2026-09-12

Impact:

``docs/README.md``, ``docs/security.md``, and ``docs/deployment-runbook.md`` describe these as open with the safe fallback behavior; the final gate (F3/F4) cannot claim CORS/CSP production readiness until the owner records the origins here.

DL-028 — OpenAPI contract is exported as JSON only; no Swagger UI is served

Xolvon Backend Documentation · decision-log.md

Problem:

T10 must publish the HTTP contract as ``docs/openapi.json`` without weakening the Bearer-only security posture. Serving the generated Swagger UI as an unauthenticated route would expose a full API map (and an interactive "try it" console) to anonymous visitors on every environment, including staging and production, at zero product benefit for API clients that already have the committed artifact.

Existing Requirement:

DL-016 (JWT Bearer-only auth); addendum Must-NOT-have "no paid/extra public attack surface without owner decision"; plan T10 acceptance ("decide Swagger UI exposure (local/internal only unless auth protected) in decision log").

Options:

- Serve ``SwaggerModule.setup()`` at ``/api/docs`` in all environments.
- Serve the UI only when ``APP_ENV=local``.
- Export the document as a committed JSON artifact and never serve a UI route.

Owner:

Founder/Backend

Decision:

The application serves NO Swagger UI in ANY environment (local included). The contract ships as the committed ``docs/openapi.json``, regenerated only by ``npm run docs:openapi`` (``src/openapi/export-openapi.ts``), which bootstraps the real app offline, forces local drivers, and fails if any live route is missing from the document. Reviewers and clients render the JSON with their own tools. Reopening UI exposure requires a new entry here plus an auth protection design.

Date:

2026-09-12

Impact:

``package.json`` gains ``docs:openapi``; ``src/openapi/*`` adds the document factory, export script, and contract tests; ``docs/openapi.json`` becomes a generated artifact checked for secret-free content by ``findSecretLeaks`` and the export spec. No new HTTP route is added to the running application.

DL-029 — Stray root Postman collection relocated into postman/ and removed

Problem:

Plan T11 requires the Postman artifacts at ``postman/xolvon-backend.postman_collection.json`` plus ``postman/environments/*.postman_environment.json``. Commit ``9a6d1d7`` (already flagged by DL-026 for its stray PDF-pair) additionally placed ``Xolvon-API.postman_collection.json`` in the repo ROOT. That collection covers all 65 canonical operations (66 requests) but cannot serve the T11 acceptance criteria: zero test scripts (so ``npx newman run`` asserts nothing and cannot be a smoke gate), zero saved success/error examples, its second login silently OVERWRITES ``accessToken`` (the admin/user token chain breaks mid-folder), no ``postman/environments/`` files exist (staging/production placeholders per DL-024 were never created), and the root location contradicts the planned layout and the single-source-of-truth rule of DL-026/T14 reconciliation.

Existing Requirement:

DL-024 (production Postman environments = names + placeholder URLs + blank secrets only); DL-025 (conservative cleanup, every deletion logged); DL-026 (this is the Postman half of the 9a6d1d7 stray disposition); plan T11 (``./omo/plans/xolvon-addendum-hardening-docs.md``).

Options:

- Keep both collections and hope consumers pick the right one.
- Move the root file as-is into postman/ (keeps the coverage gap and broken layout).
- Rebuild the canonical collection at postman/ from docs/openapi.json, port every useful request from the stray file (its token-capture login flow, folder taxonomy, and placeholder bodies are all carried over), then delete the root copy under this ledger entry.

Owner:

Founder/Backend

Decision:

Option 3 executed at T11. `postman/xolvon-backend.postman\_collection.json` (11 folders / 75 requests) now covers ALL 65 openapi operations (checked-verified against Docs/openapi.json). With class-validator-legal placeholder bodies, per-request Newman test scripts, saved success + 401/403/404/409/429 examples whose error envelopes match the real guard/service throw strings, Bearer token capture into collection variables (cookie jar explicitly unused – the API is Bearer-only), and a self-contained `10. Newman Smoke` folder. Environments ship under `postman/environments/{local,staging,production}.postman\_environment.json`; staging/production contain placeholder URLs and blank secret variables per DL-024, and final staging/production origins remain OPEN per DL-027. `npm run test:newman` is the documented local smoke path. The root `Xolvon-API.postman\_collection.json` is DELETED in the same commit as the replacement (this entry is its ledger line). The stale root README \$ "Postman Collection Integration" link is left for the T14 docs-reconciliation pass rather than expanded into this test commit.

Date:
2026-09-12

Impact:
Single canonical Postman artifact; the stray root file no longer misleads consumers; T14 reconciles README prose. No environment secret is committed (secret scan recorded in .omo notepad evidence t11). Deletion is reversible: the old file remains recoverable from `git show 9a6d1d7:Xolvon-API.postman\_collection.json`.

Cleanup ledger (T12)

Executed 2026-09-12 under the DL-025 conservative cleanup policy. Audit covered

`git status`, `git ls-files`, `git ls-files -o --exclude-standard`, and a

root/subfolder scan for `*.tmp`, `*.bak`, `*.log`, `Thumbs.db`, `.DS_Store`

(none tracked, none present). Tracked total before and after: 266 files — no

tracked file was deleted by this task; every deletion below is an untracked,

gitignored working-copy remnant of a scratch file that was previously committed

and already purged from tracking by commit `e91dc97` ("chore: cleanup gitignore,

purge scratch artifacts"). Each deleted file's full content remains recoverable

from history via `git show e91dc97^:<path>`.

Deleted (proven stale scratch, zero tracked references — verified by `git grep`)

Path	Reason	Recovery
<code>t15-verification.md</code>	Stale T15 verification scratch at repo root; no reference in any tracked doc/script/test.	<code>git show e91dc97^:t15-verification.md</code>
<code>t3-happy.txt</code>	Stale T3 evidence scratch at repo root; only cross-referenced by the untracked root <code>DoneClaim</code> scratch file itself, not by tracked material.	<code>git show e91dc97^:t3-happy.txt</code>
<code>t3-failure.txt</code>	Same as above.	<code>git show e91dc97^:t3-failure.txt</code>
<code>learning-t3.md</code>	Stale T3 learning scratch at repo root; only referenced by the untracked <code>DoneClaim</code> scratch, not by tracked material.	<code>git show e91dc97^:learning-t3.md</code>

Kept — needs owner decision (referenced by tracked `docs/qa-results.md`)

Path	Why kept
<code>DoneClaim</code>	Untracked scratch, but <code>docs/qa-results.md</code> §T19 cites it by name as the historical record that production credentials were never exercised. Deleting would strand a live documentation reference. Owner may delete once T14 reconciles the qa-results prose.
<code>evidence-t19-happy.txt</code>	Same: cited by name in <code>docs/qa-results.md:34-35</code> .
<code>evidence-t19-failure.txt</code>	Same: cited by name in <code>docs/qa-results.md:34-35</code> .

Path	Why kept
Xolvon Backend Documentation · <code>t20-happy.txt</code>	<code>decision-log.md</code> Cited by name in <code>docs/qa-results.md</code> (BLOCKED-gate evidence for T20).
<code>t20-failure.txt</code>	Cited by name in <code>docs/qa-results.md</code> (BLOCKED-gate evidence for T20).

Disposition notes (NOT deletions; guarded per T12 scope)

- No tracked file under `src/`, `migrations/`, `test/`, or this

`docs/decision-log.md` was removed or altered beyond this ledger append.

- The out-of-band root `README.md` rewrite (commit `65ecc4d` era / post-T work)

and its stale `Xolvon-API.postman_collection.json` link are left untouched —

owned by the T14 docs-reconciliation pass (already anticipated by DL-029).

- `.omo/` and `docs/pdf/` were not touched (committed artifacts by owner

decision, DL-019/DL-026).

- No git history was rewritten; nothing was reset, rebased, or reverted.

Environment / secret hygiene findings

- `git ls-files | grep -E '(^/)\.env$' → empty`: no real `.env` is tracked.
- `git log --all --oneline -- .env '**/.env' → empty`: no real `.env` was ever

tracked in history. No security-incident/rotation action required.

- `.gitignore` verified: ignores `.env`, `.env.*` (with `!.env.example /`

`!.env.*.example` exceptions), `local.db / local.db-journal / local.db-wal /`

`local.db-shm / *.db*`, `DoneClaim`, `evidence-*.txt`, `learning-*.md`,

`t[0-9]*-*.txt`, `t[0-9]*-*.md`, `/ .omo`, `.codegraph`, `dist`, `buildinfo`,

OS junk (`.DS_Store`, `Thumbs.db`), and `*.tmp / tmp/` patterns.

- `.env.example`, `.env.local.example`, `.env.staging.example`,

`.env.production.example` all remain present and unmodified.

- Variable-name reconciliation vs `src/config/env.validation.ts`: MATCH — every

validated variable (`JWT_SECRET`, `FRONTEND_URL`, `PORT`, `APP_ENV`,

`DB_DRIVER`, `STORAGE_DRIVER`, `CLOUDFLARE_ACCOUNT_ID`,

`CLOUDFLARE_D1_DATABASE_ID`, `CLOUDFLARE_API_TOKEN`, `R2_ENDPOINT`,

`R2_BUCKET`, `R2_ACCESS_KEY_ID`, `R2_SECRET_ACCESS_KEY`) appears in the

example files. No silent source edits were made.

- FLAG (informational, no action by T12): `CORS_ALLOWED_ORIGINS` is consumed by

`src/config/cors.ts` (falls back to `FRONTEND_URL`, then the local dev

origin, so bootstrapping is unaffected) but is documented in none of the

four example files. Owner/docs task should add it to `.env.staging.example`

and `.env.production.example` alongside the DL-027 final-origin decision.

Dependency vulnerability management (T13)

DL-030 — Dependabot + npm audit as the scanning approach; 4 residual HIGHs are owner decisions

Problem:

T2/T13 ``npm audit --json`` (2026-09-12, evidence `` .omo/notepads/xolvon-addendum-hardening-docs/evidence/t13-audit-before.json``) reports 0 critical, 4 high, 1 moderate, 2 low. ``npm audit fix`` (non-breaking, no ``--force``) is a verified no-op: it exits 1 with the identical 7 findings and produces an empty git diff on `package.json/package-lock.json` — every fix is

either unavailable or semver-major/breaking, so no safe automated remediation exists today. Per the addendum rule "no paid scanner without owner decision" (DL-023), the recurring scan mechanism must be chosen and the unfixable HIGHS must be recorded, not silently left open.

Existing Requirement:

DL-023 (scanner choice was OPEN, paid vendor requires owner approval); plan T13 (`.omo/plans/xolvon-addendum-hardening-docs.md`); addendum §1.5.

Options:

- (a) Paid scanner vendor – rejected, requires owner approval per DL-023.
- (b) Dependabot (free, repository-native, GitHub-hosted) – selected.
- (c) Manual periodic `npm audit` only – no continuous coverage.

Decision:

1. Scanning approach: GitHub Dependabot via `.github/dependabot.yml` – weekly npm version updates (mon 07:00 Asia/Jakarta, minor+patch grouped, open-pull-requests-limit: 5, commit-message prefix `chore` to match repo style) plus the github-actions ecosystem. npm audit remains the local gate (`npm audit --json` in final verification). No paid scanner/vendor was added. Enabling Dependabot security updates in repository settings is an owner/repo admin action (GitHub UI), noted here as the activation dependency.
2. Residual HIGH advisories – owner decisions, deliberately NOT auto-fixed (all fixes are breaking or nonexistent; forcing them would violate the no-break-the-build rule and this repo does not touch app source for audit):

- multer <=2.2.0 [HIGH] (4 advisories incl. GHSA-wc9g-mqfw-jrwm DoS via crafted multipart field names; GHSA-qfvm-cv95-jqjf fd-leak DoS; GHSA-535w-7cp7-47q4 oversized-array-index DoS; GHSA-qvfw-j98x-7q72 size -limit bypass [low-severity sub-advisory]) pulled in by @nestjs/platform-express@12.0.1. fixAvailable=false: the newest @nestjs/platform-express (12.0.1) still pins multer@2.2.0 and multer@2.3.0 (the fixed line) is not consumed by any platform-express release. Why not auto-fixed: would require either waiting for an upstream NestJS patch or adding a package.json "overrides" entry for multer@^2.3.0 – an unaudited manifest change outside this task's permitted remediation set. Owner options: add `overrides: {"multer": "^2.3.0"}` after validating the upload paths (admin media upload, payment-proof), or wait for @nestjs/platform-express to ship the bump. Mitigating facts: multer is only reached through Nest platform-express multipart routes; core app uploads flow through presigned R2 URLs, not multipart bodies.

- @nestjs/platform-express * [HIGH] – same finding surfaced on the direct dependency (via: multer). Same owner decision as above.

- undici <=6.27.0 [HIGH] (15 advisories incl. GHSA-f269-vfmq-vjvj WebSocket length overflow crash; GHSA-vrm6-8vpv-qv8q unbounded memory; GHSA-v9p9-hfj2-hcw8 unhandled exception; GHSA-vxpw-j846-p89q fragment DoS) and tmp <=0.2.5 [HIGH] (GHSA-ph9p-34f9-6g65 path traversal; GHSA-52f5-9888-hmc6 symlink write), plus @nestjs/mau * [MODERATE] and the two linked LOWs (inquirer 3.0.0-8.2.6||9.0.0-9.3.7 via external-editor; external-editor >=1.1.1 via tmp): ALL reachable only through the devDependency @nestjs/mau@0.2.6 (chain: @nestjs/mau -> ... -> undici; @nestjs/mau -> inquirer -> external-editor -> tmp). The only fix npm offers is @nestjs/mau@0.0.6 marked isSemVerMajor:true – a downgrade to a much older artifact, breaking, and 0.0.6 does not even appear in the package's published version list. Why not auto-fixed: major/breaking, explicitly out of safe scope. Owner options (recommended): verify @nestjs/mau is genuinely unused (grep of src/test/scripts/nest-cli.json finds ZERO references – it appears to be leftover Nest CLI tooling) and `npm uninstall @nestjs/mau`, which closes 1 moderate + 2 high + 2 low in one step with no runtime impact; or pin and accept, since all four dev-only packages never ship in `dist/` and are not reachable in the production runtime (npm-start path is `node dist/main` with no inquirer/tmp/undici imports from app code).

Date:

2026-09-12

Impact:

Continuous dependency scanning lands without any paid vendor (DL-023 closed: Dependabot selected). Gates stay green untouched by dependency churn (package.json/package-lock.json unchanged this task). The 4 HIGH + 1 MODERATE + 2 LOW residuals become explicit, dated owner decisions with concrete paths instead of audit noise; production runtime is dev-only-surface for 6 of the 7

findings, and the multer pair depends on an upstream NestJS release or a reviewed overrides entry.